

Security Policy

Reporting a Vulnerability

Do not open a public GitHub issue for security vulnerabilities. Contact the maintainer directly.

API Key Security

All API keys must be stored in `.env` (excluded from git) and never hardcoded in source files.

If you suspect a key has been committed to this repo, rotate it immediately:

- Google Maps: console.cloud.google.com/apis/credentials
- SerpAPI: serpapi.com/dashboard

To check your git history for leaked keys:

```
bash
git log -p | grep -E "AIza|SERP|apiKey" | head -40
```

To purge a key from history:

```
bash
pip install git-filter-repo
git filter-repo --replace-text <(echo "OLD_KEY==>REMOVED")
git push origin main --force
```

npm Vulnerability Remediation Log

All issues were resolved as part of the Expo migration. Fixed by upgrading the packages listed below.

High Severity

Package	Vulnerability	Fixed Version
<code>node-forge</code>	ASN.1 Unbounded Recursion	<code>^1.3.1</code>
<code>node-forge</code>	ASN.1 Validator Desynchronization	<code>^1.3.1</code>

Package	Vulnerability	Fixed Version
<code>node-forge</code>	OID Integer Truncation	<code>^1.3.1</code>
<code>tar</code>	Race condition via Unicode ligature collisions (macOS APFS)	<code>^7.4.3</code>
<code>tar</code>	Arbitrary file creation via hardlink path traversal	<code>^7.4.3</code>
<code>tar</code>	Arbitrary file overwrite via symlink poisoning	<code>^7.4.3</code>
<code>tar</code>	Hardlink path traversal via drive-relative linkpath	<code>^7.4.3</code>
<code>tar</code>	Symlink path traversal via drive-relative linkpath	<code>^7.4.3</code>
<code>tar</code>	Arbitrary file read/write via symlink chain	<code>^7.4.3</code>
<code>minimatch</code>	ReDoS via repeated wildcards	<code>^9.0.5</code>
<code>minimatch</code>	ReDoS via non-adjacent GLOBSTAR segments	<code>^9.0.5</code>
<code>minimatch</code>	ReDoS via nested extglobs	<code>^9.0.5</code>
<code>axios</code>	DoS via <code>__proto__</code> key in <code>mergeConfig</code>	<code>^1.9.0</code>
<code>undici</code>	Unbounded memory in WebSocket decompression	<code>^6.21.1</code>
<code>undici</code>	64-bit length overflow crashes WebSocket client	<code>^6.21.1</code>
<code>undici</code>	Unhandled exception via invalid <code>server_max_window_bits</code>	<code>^6.21.1</code>
<code>fast-xml-parser</code>	Numeric entity expansion bypasses limits	<code>^4.5.0</code>
<code>fast-xml-parser</code>	DoS via DOCTYPE entity expansion	<code>^4.5.0</code>

Moderate Severity

Package	Vulnerability	Fixed Version
<code>undici</code>	HTTP request/response smuggling	<code>^6.21.1</code>
<code>qs</code>	<code>arrayLimit</code> bypass allows memory exhaustion DoS	<code>^6.14.0</code>

Google Maps CocoaPods Deprecation

Google Maps Platform will stop releasing iOS SDK versions via CocoaPods starting **Q2 2026** (version 11.0+).

Affected project: `pathfinder-454522`

Action required: Migrate `ios/` to Swift Package Manager. See [DOCUMENTATION.md](#) → [iOS SPM Setup](#).

Production Secrets

For production builds, never put keys in `app.json` or source files. Use EAS Secrets:

```
bash
```

```
eas secret:create --scope project --name GOOGLE_MAPS_API_KEY --value "AIza..."  
eas secret:create --scope project --name SERPAPI_KEY --value "..."
```

These are injected at build time and never stored in the repository.